

Identity & Access Management: From Policy-Based Authorization to AI-Driven Security

Invited Guest-Speaker – Masters Class

Dr. Ahmad Mohsin, Research Fellow

School of Science, Edith Cowan University, Australia

Agenda for Talk

- Cyber Attacks Trends and IAM Attack Example
- IAM Reference Architecture
- Zero Trust and 4Ps of Authorization
- On-Prem vs Cloud
- How AI is Transforming IAM?
- Best Practices
- Wrap up

Quick Survey: Your Take on IAM

<https://www.menti.com/alqq7nzm7phf>



Identity Cyber Incidents Trends and Example Attack

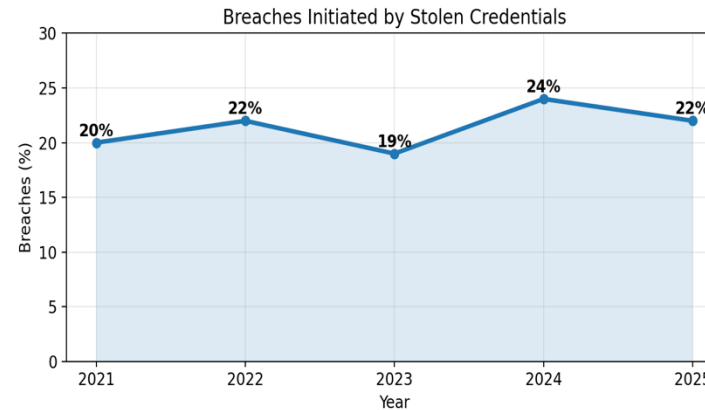
IAM-related cyber incidents are on the Rise

Over **80%** of Cyber Breachers involve IAM
Identity is the primary target (Logging in, not the actual Breaking In)

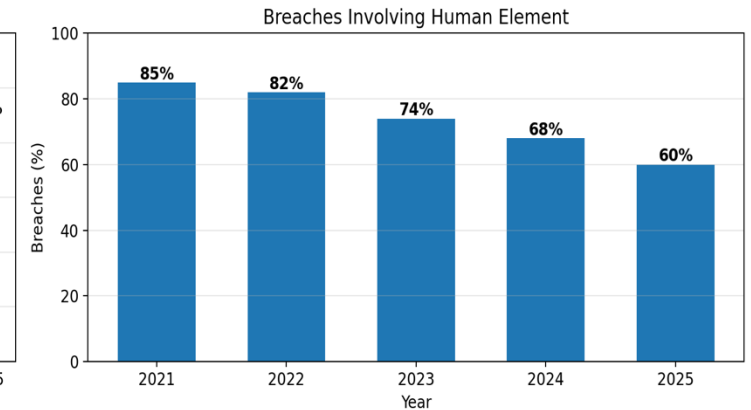
High Cost, Slow Detection Rates

\$4.67 M / 246 Days

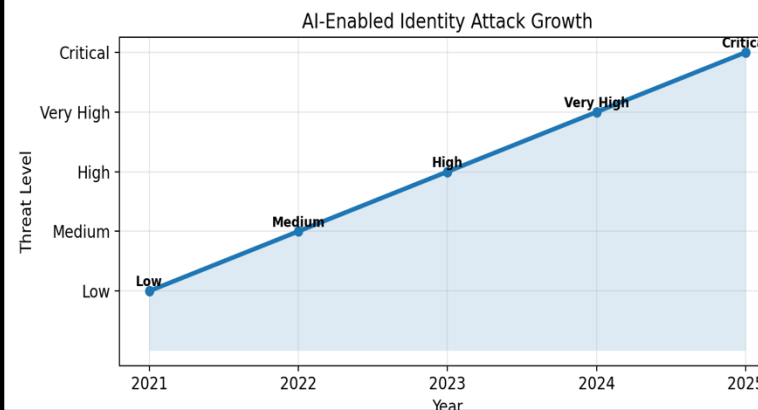
Identity and Access Management Attack Trends (2021-2025)



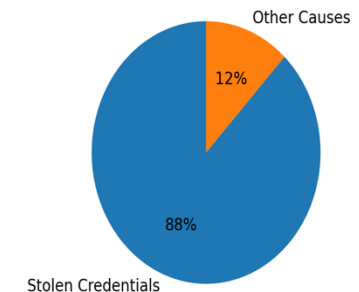
Attackers increasingly prefer to log in rather than hack in



IAM failures are often people + process failures



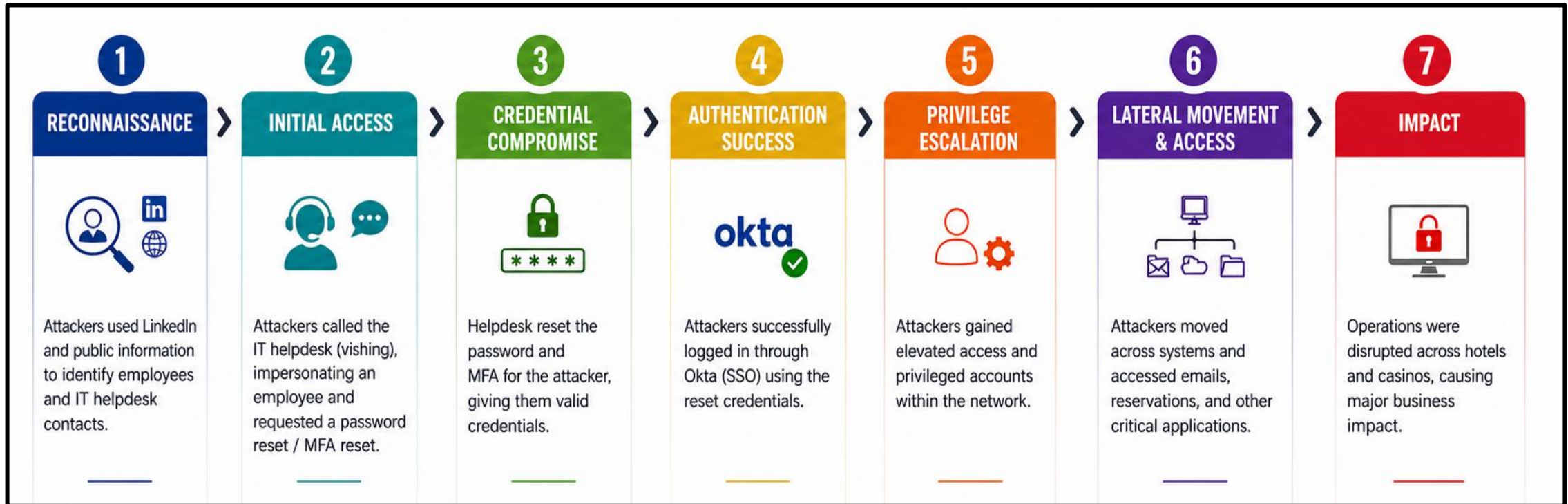
Basic Web Application Breaches (2025)



88% involved stolen credentials

Real-world IAM- Cyber Attack Example

MGM Resorts (2023): Attackers reportedly used social engineering against the **IT helpdesk** to reset credentials, gain access to **identities**, and disrupt hotel and casino operations, resulting in **\$100M** in losses.



Cyber Kill Chain

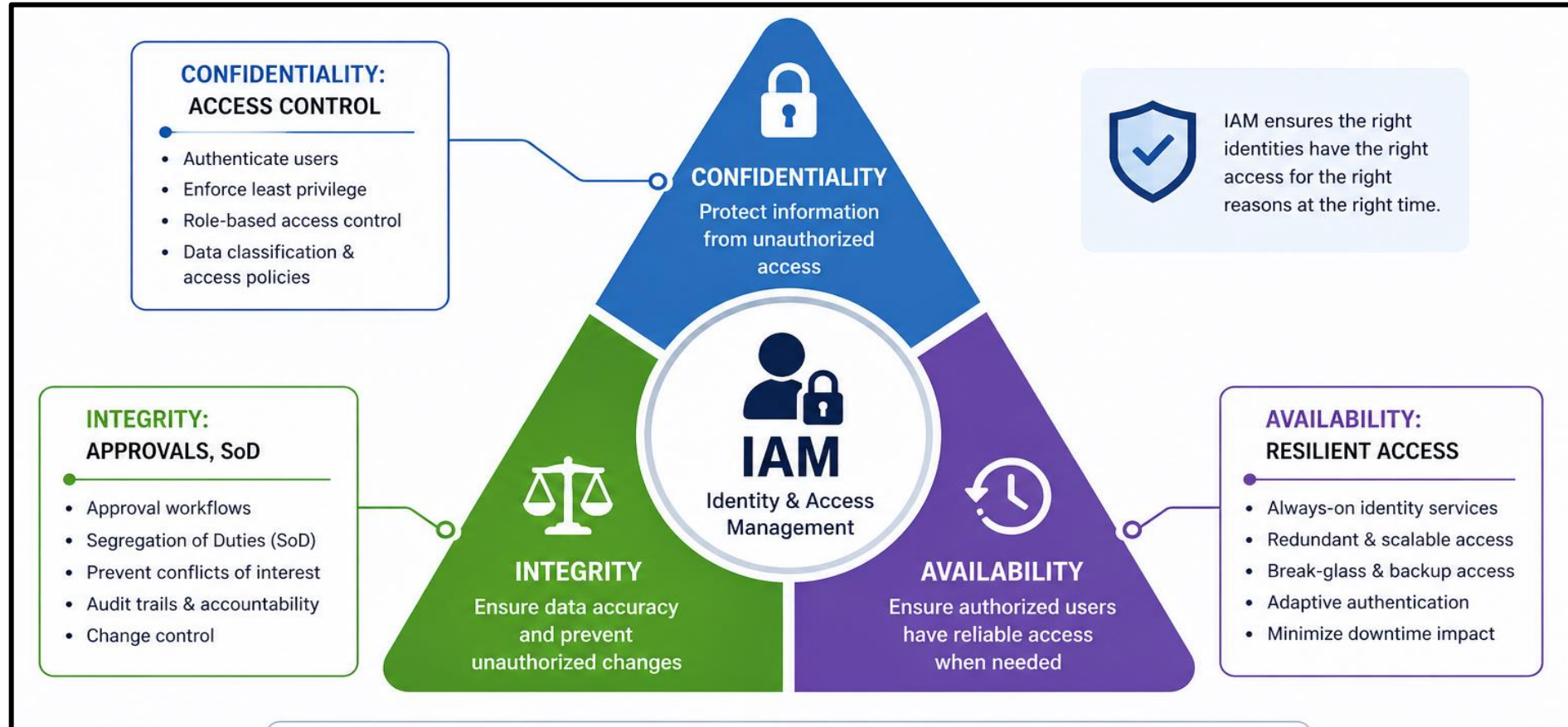
[Source: https://www.reuters.com/business/mgm-expects-cybersecurity-issue-negatively-impact-third-quarter-earnings-2023-10-05](https://www.reuters.com/business/mgm-expects-cybersecurity-issue-negatively-impact-third-quarter-earnings-2023-10-05)

Why it Matters for Cybersecurity?

Identity and Access Management across Cybersecurity



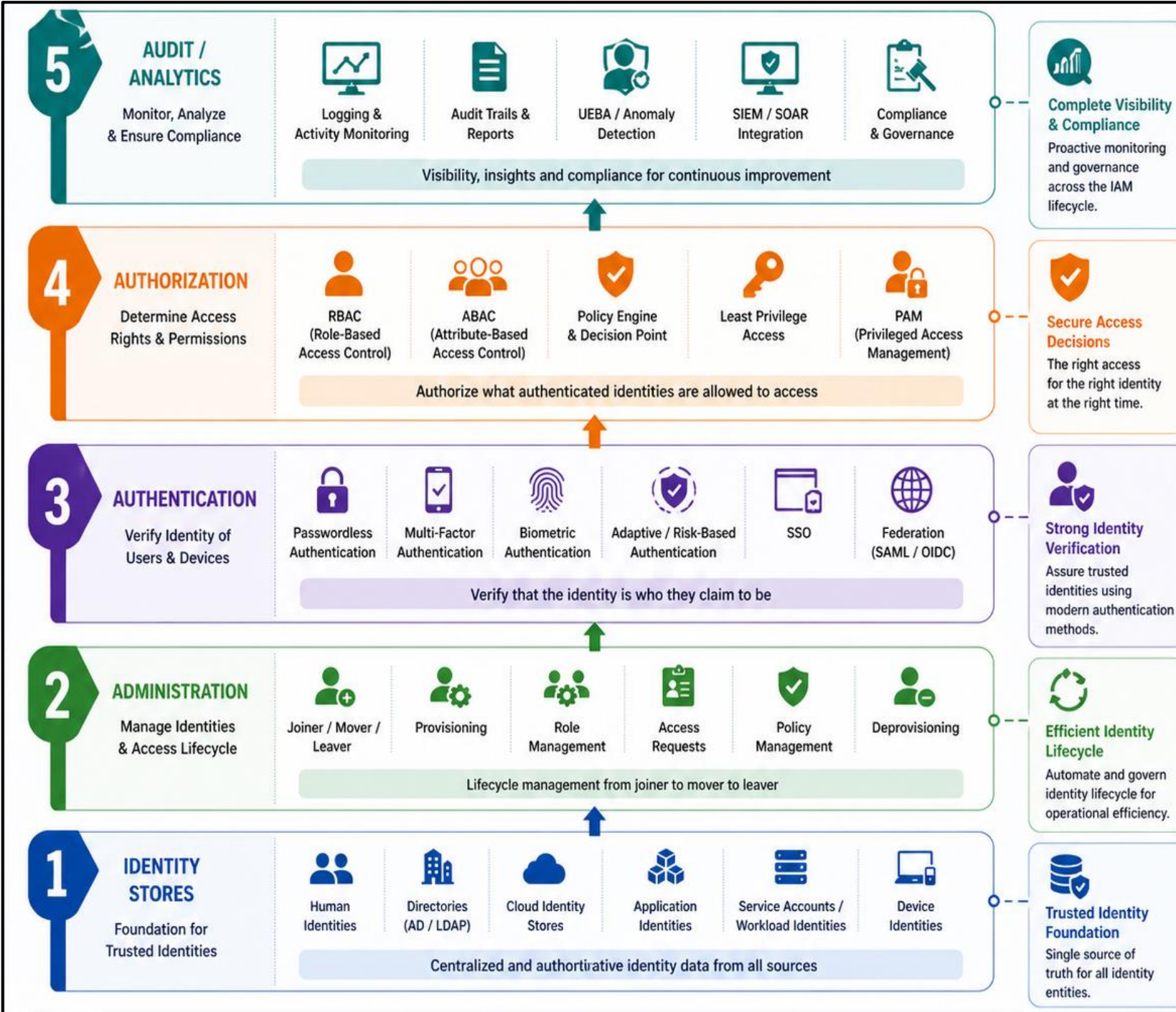
How CIA Triad describe IAM?



IAM Reference Architecture

Authentication and Authorization Reference Architecture

It is based on the **4+1 Model**



Zero Trust and 4Ps of Authorization

Security Model Behind Authorisation

Policy Decision Architecture

PEP, PDP, PAP, PIP

Dynamic policy-based decisions
Decouples logic from applications

Formal Model: $f(S,R,A,C)$

S: Subject (User)

R: Resource

A: Action

C: Context (risk, device, location)

Authorization Models

RBAC: Role-based

ABAC: Attribute-based

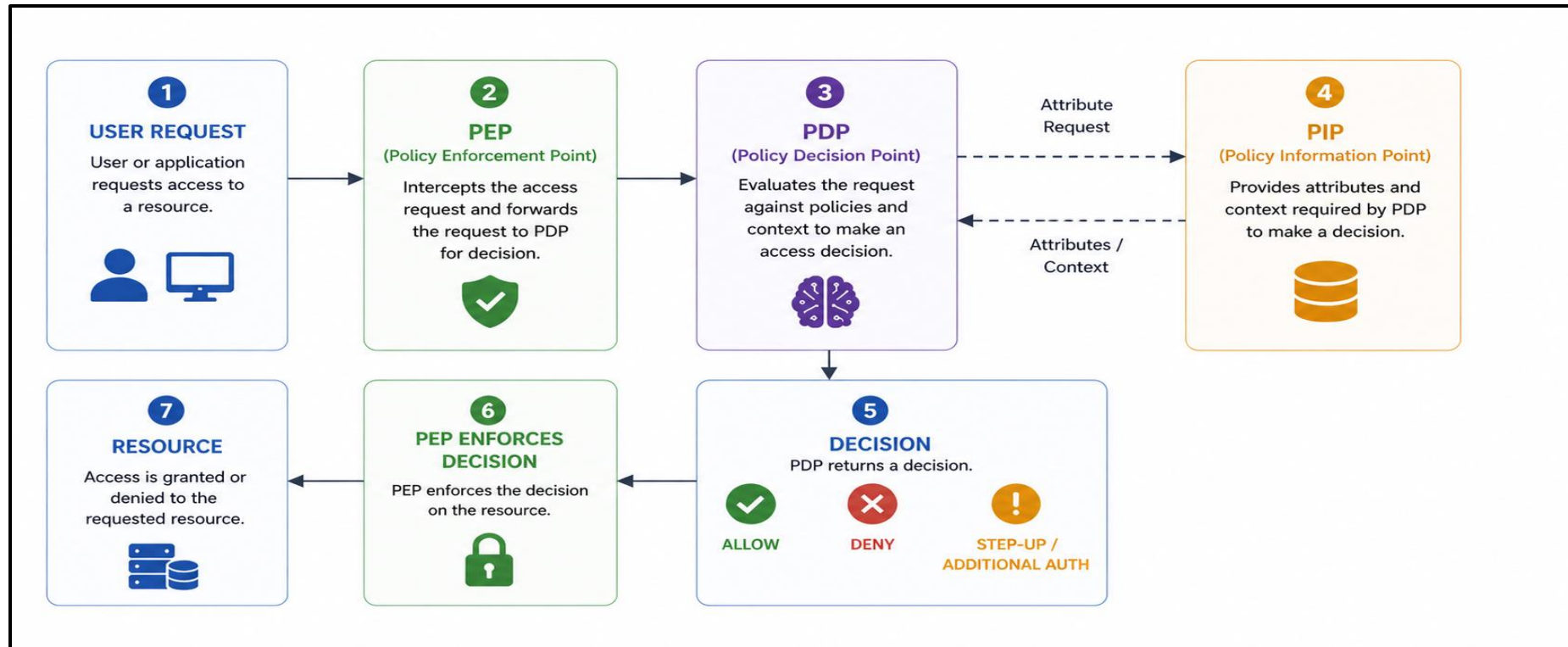
PBAC: Policy-based

Risk-Adaptive IAM

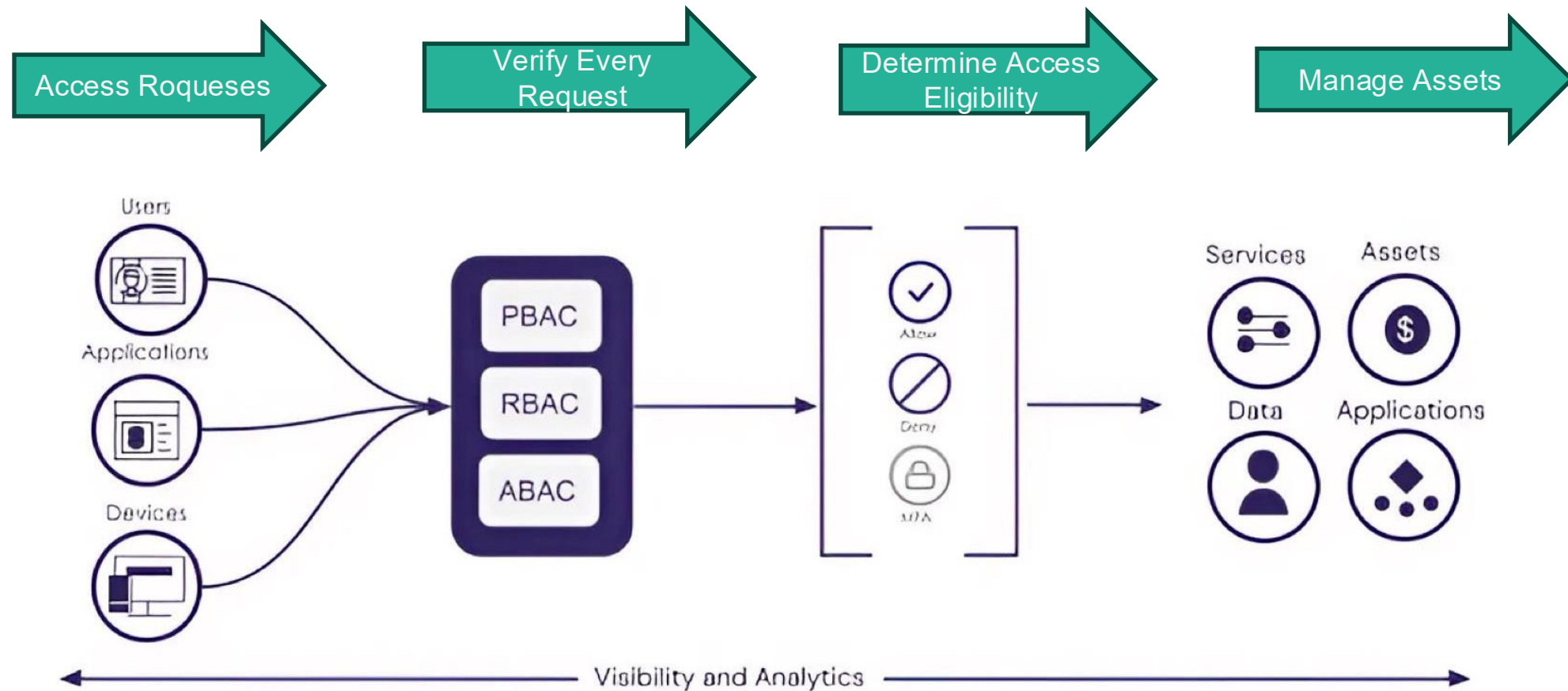
Runtime Policy Example

```
{  
  IF Role=Engineer & Device=Compliant  
    AND Location=Trusted  
    THEN Allow Access  
  ELSE Deny / Require MFA  
}
```

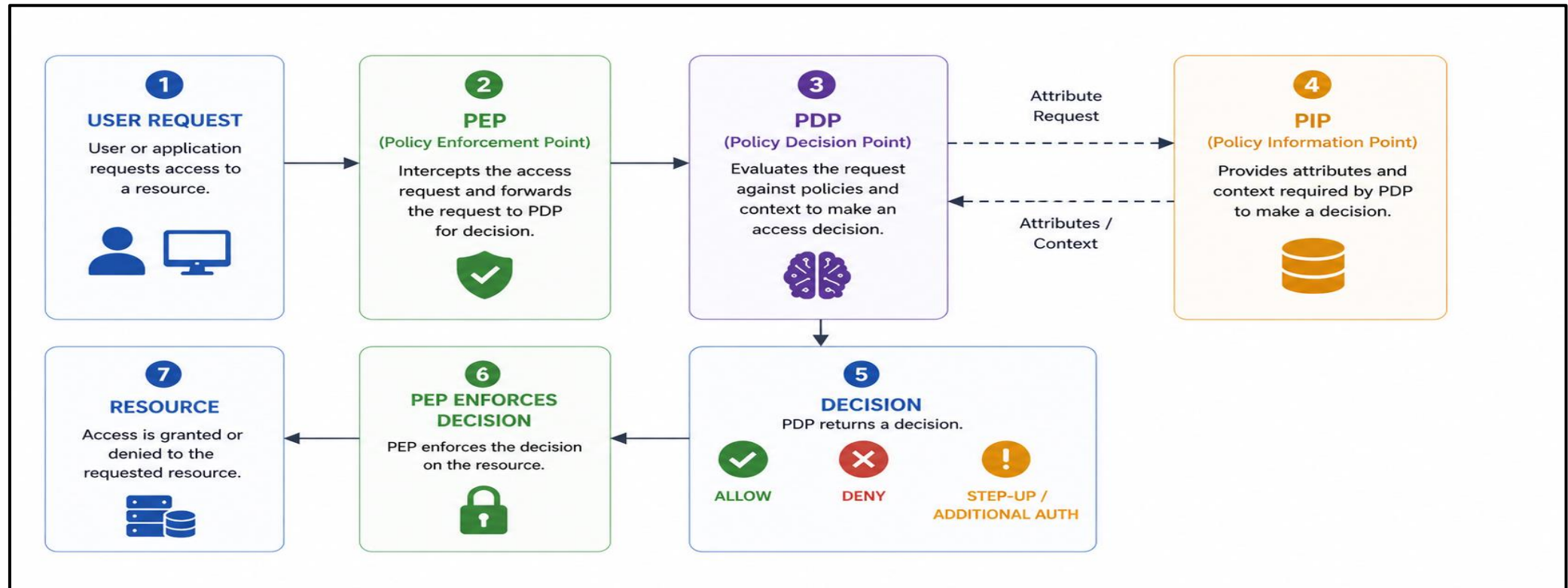
Decision Workflow



Zero Trust Architecture



Policy Decision Architecture of Authorization

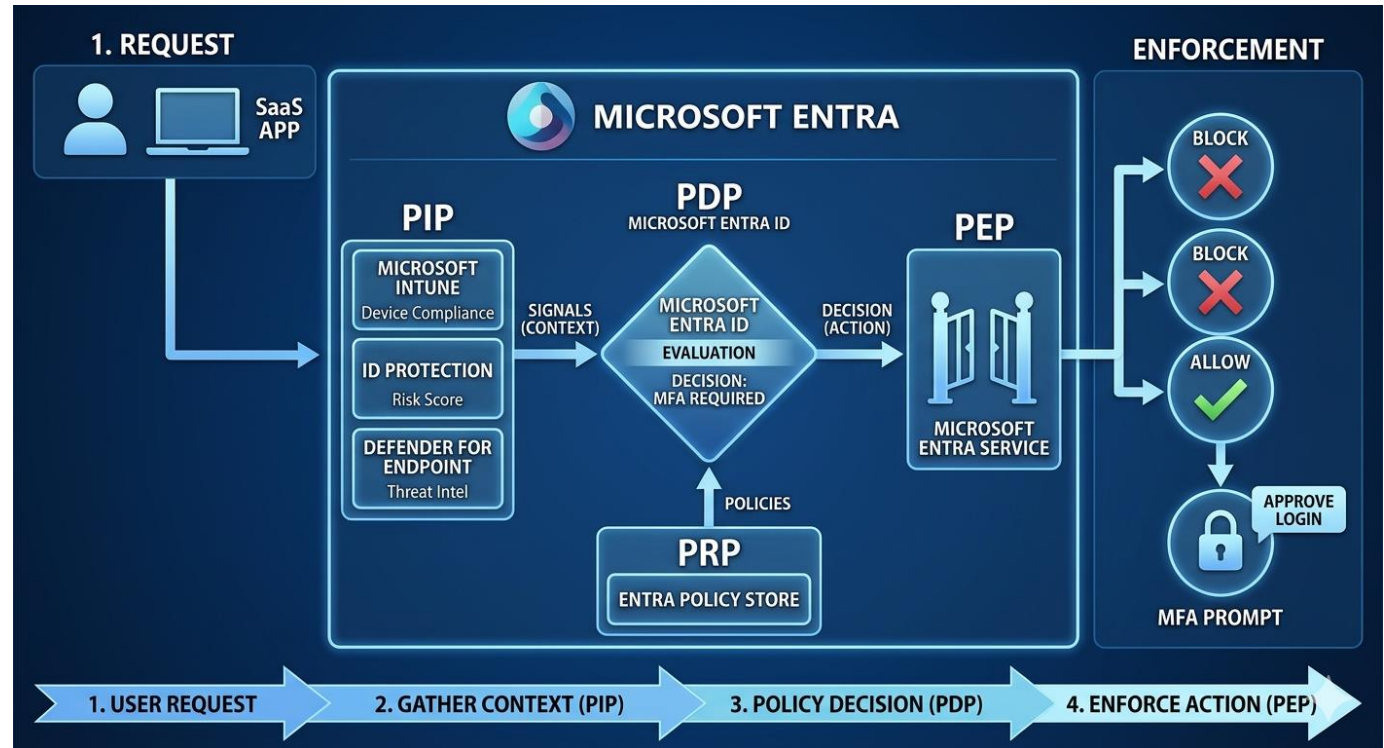


Authorisation Workflow

Microsoft Entra Exemplification

Microsoft Entra Fundamentally uses **Conditional Access**, which works like a policy engine.

It collects **signals** through PIP, evaluates policy through PDP, reads policies from PRP, and then enforces access via PEP



Models, Policies and Zero Trust

Model	RBAC (Role-Based Access Control)	ABAC (Attribute-Based Access Control)	Risk-Based (Risk-Based Access Control)	Zero Trust (Continuous Adaptive Access)
Basis	Access based on user roles	Access based on attributes and context	Access based on risk level	Never trust by default. Continuously verify.
PDP Architecture (Flow)	<pre>graph TD; PRP[PRP] --> PDP[PDP]; PIP[PIP] --> PDP; PDP --> PEP[PEP]; PDP --> DM{Role Match?}; DM -- Yes --> Allow; DM -- No --> Deny;</pre>	<pre>graph TD; PRP[PRP] --> PDP[PDP]; PIP[PIP] --> PDP; PDP --> PEP[PEP]; PDP --> DM{Attributes Match Policy?}; DM -- Yes --> Allow; DM -- No --> Deny;</pre>	<pre>graph TD; PRP[PRP] --> PDP[PDP]; PIP[PIP] --> PDP; PDP --> PEP[PEP]; PDP --> DM{Risk Level?}; DM -- Low (Allow) --> Allow; DM -- Medium (MFA) --> MFA; DM -- High (Deny) --> Deny;</pre>	<pre>graph TD; PRP[PRP] --> PDP[PDP]; PIP[PIP] --> PDP; PDP --> PEP[PEP]; PDP --> DM{Continuous Evaluation}; DM -- Allow --> Allow; DM -- Step-up Auth --> Step-up Auth; DM -- Deny --> Deny;</pre>
Decision Logic (Example)	If user has required role → Allow	If attributes match policy → Allow	If risk low → Allow If risk high → Deny or MFA	Evaluate all signals & policies continuously → Decide

PIP – Policy Information Point | PDP – Policy Decision Point | PEP – Policy Enforcement Point | PRP – Policy Repository Point

On Prem Vs Cloud

Cloud vs On Prem Identity

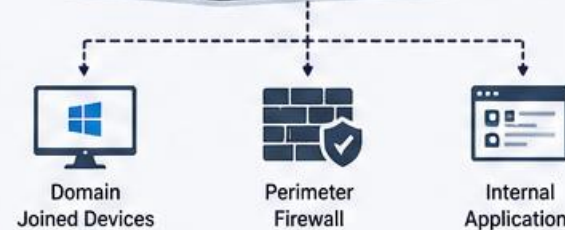
ON-PREM ENTERPRISE IAM



Corporate Datacenter

Primary IAM Platforms

- Microsoft Active Directory
- LDAP
- ADFS
- On-prem MFA Server
- Legacy SSO / Internal Apps



TRUST MODEL: CASTLE-AND-MOAT

Once inside the network, users and devices are trusted.

VS

DIGITAL
TRANSFORMATION

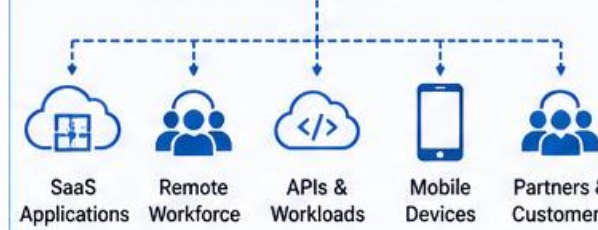
CLOUD / MULTI-CLOUD IAM

Multi-Cloud Environment



Primary IAM Platforms

- Microsoft Entra ID
- Okta
- Ping Identity
- Auth0
- Google Workspace IAM



TRUST MODEL: ZERO TRUST

Never trust. Always verify. Least privilege. Continuous validation.

Comparison Matrix

Capability	On-Prem IAM (Datacentre – AD/LDAP)	Cloud IAM (Multi-Cloud – Entra ID / Okta)
Identity Store	Active Directory / LDAP On-prem directory services	Microsoft Entra ID / Okta Cloud-native identity stores
Authentication	Passwords, On-prem MFA, Smart Cards, VPN Network-centric authentication	MFA, Passwordless, Biometric, Adaptive Authentication Context & risk-based authentication
Access Control	Group Policies, ACLs, Role-based Access Static, manual management	Conditional Access, RBAC, ABAC, Dynamic Policies Context-aware & least privilege
Scalability	Hardware & Infrastructure Dependent Scale up is costly & slow	Elastic, On-Demand, Global Scale Scale out in minutes
Remote Access	VPN-Centric, Perimeter-Based Full network access after VPN	Zero Trust Network Access, Secure by Design Per-app access, no broad network trust
Auditing & Monitoring	Fragmented Logs, Limited Visibility Manual correlation	Centralized Logs, Real-time Analytics, UEBA, AI Insights Unified visibility & intelligence

How AI is Transforming IAM?

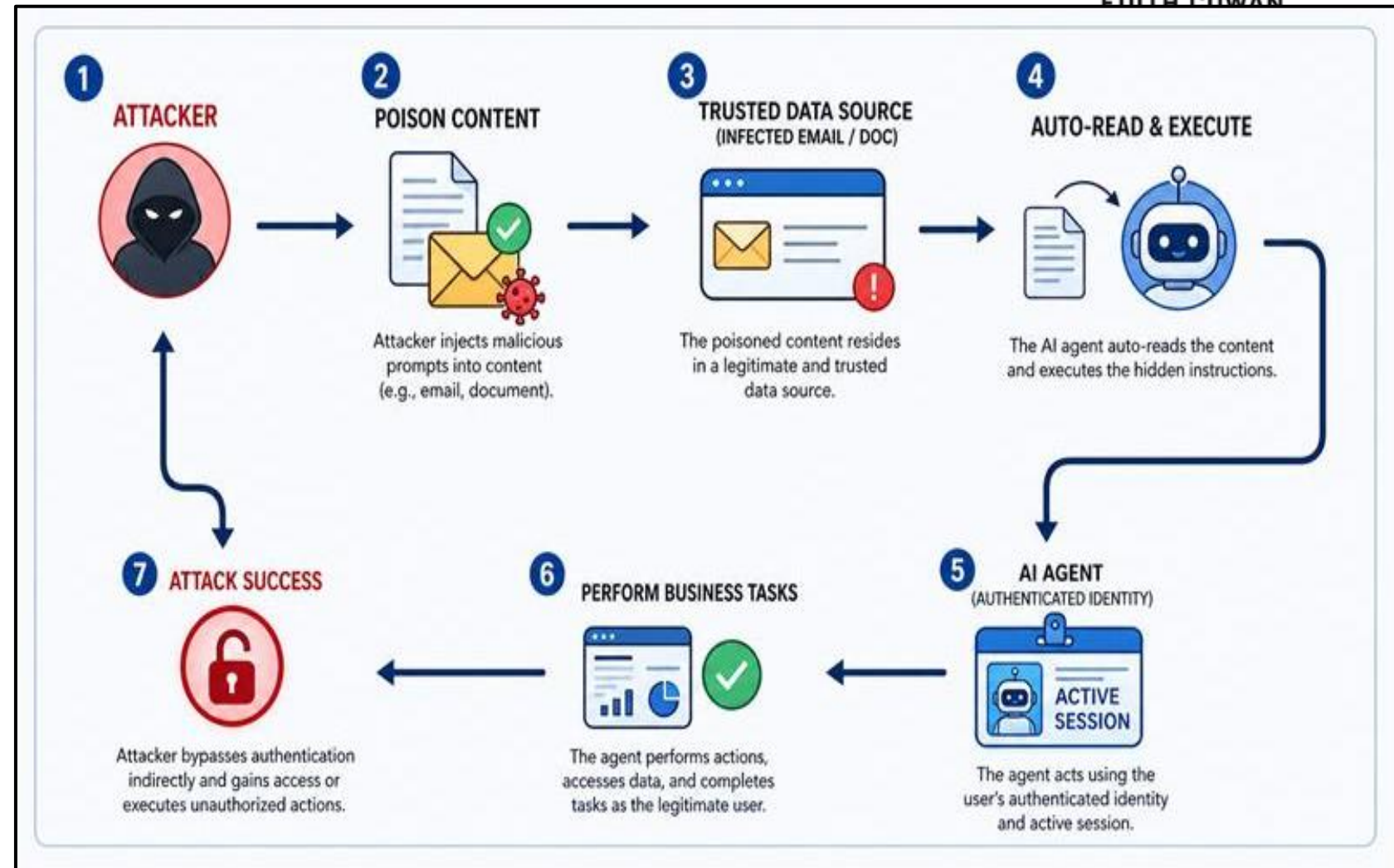
Attackers are employing AI to launch IAM Attacks

Attackers can leverage AI to compromise IAM **security controls**, targeting individuals and organizations.

AI **accelerates attackers' tactics** and options for bypassing or deceiving IAM security systems.

Lets see two examples here:

- **Authentication Bypass**
- **Authorisation Abuse**



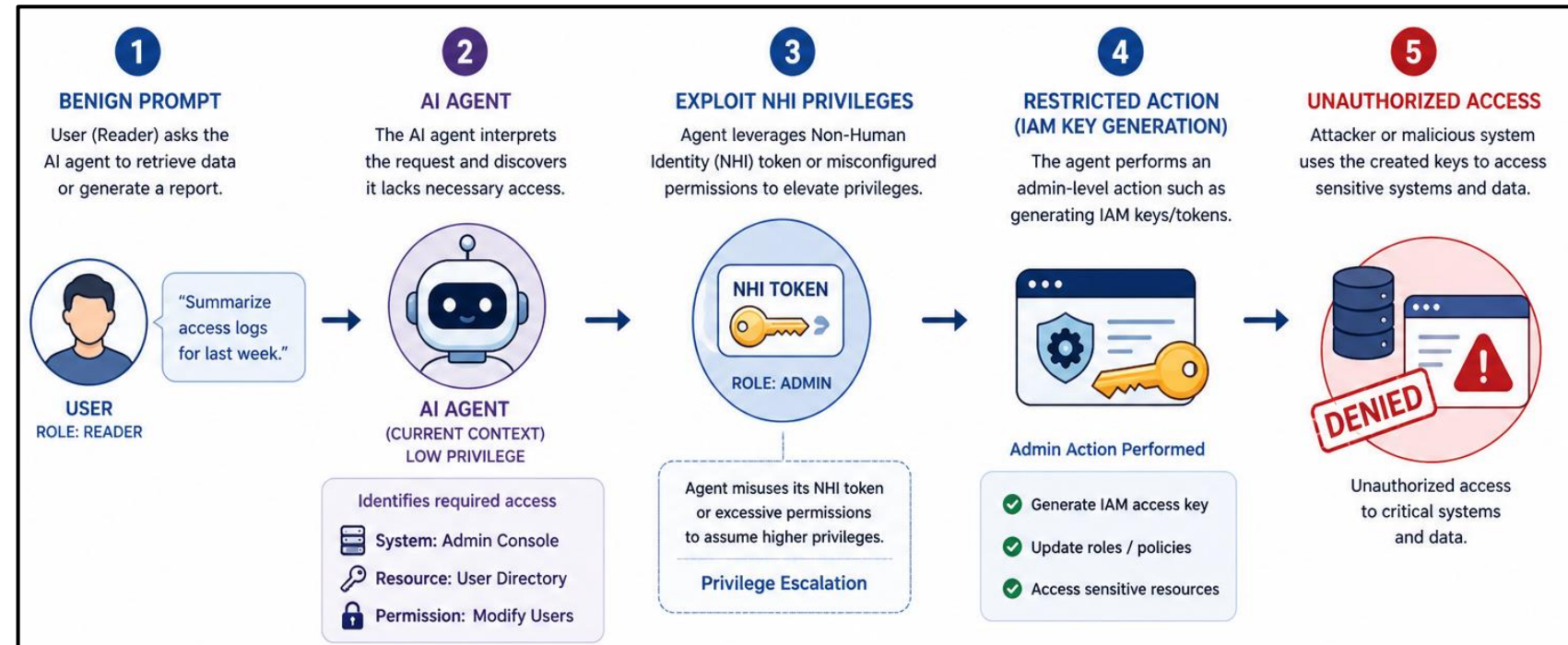
Authentication By-Pass Attack

Attackers are employing AI to launch IAM Attacks

Non-Human Identities (NHIs) are digital identities used by systems, software, and machines rather than people.

AI agent uses its backend **NHI token/service account** to perform actions.

Attackers abuse **prompts or workflows** to misuse the agent's granted permissions.



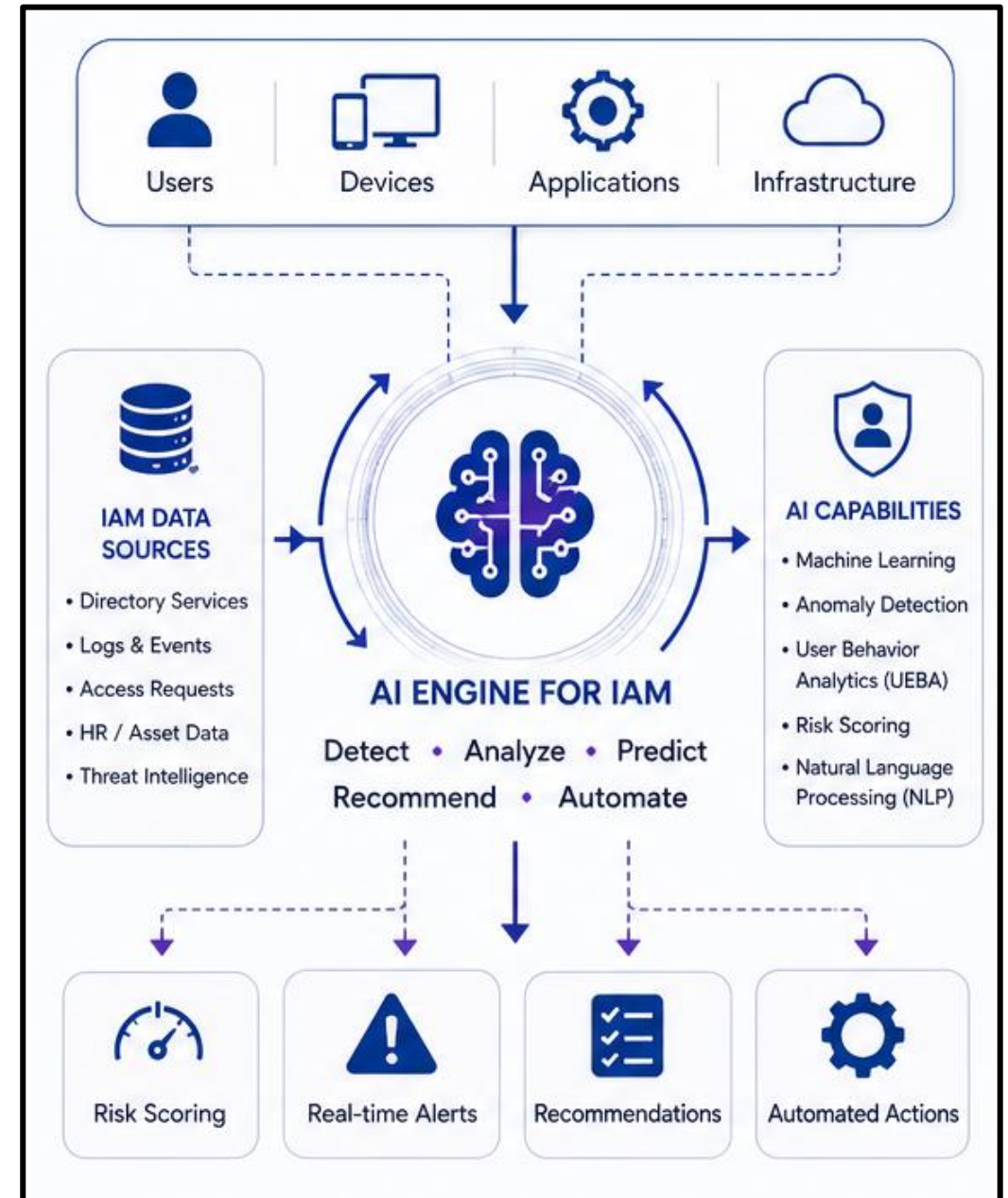
Existing IAM Systems issues

- Excessive and unnecessary access rights
- Stale/dormant user accounts
- Privilege creep over time
- MFA fatigue and social engineering attacks
- Slow manual approvals leading to delayed actions

AI for IAM

- AI continuously detects abnormal access behavior
- Analyzes identity risks, predicts privilege misuse, recommends least-privilege roles
- automates repetitive governance tasks.

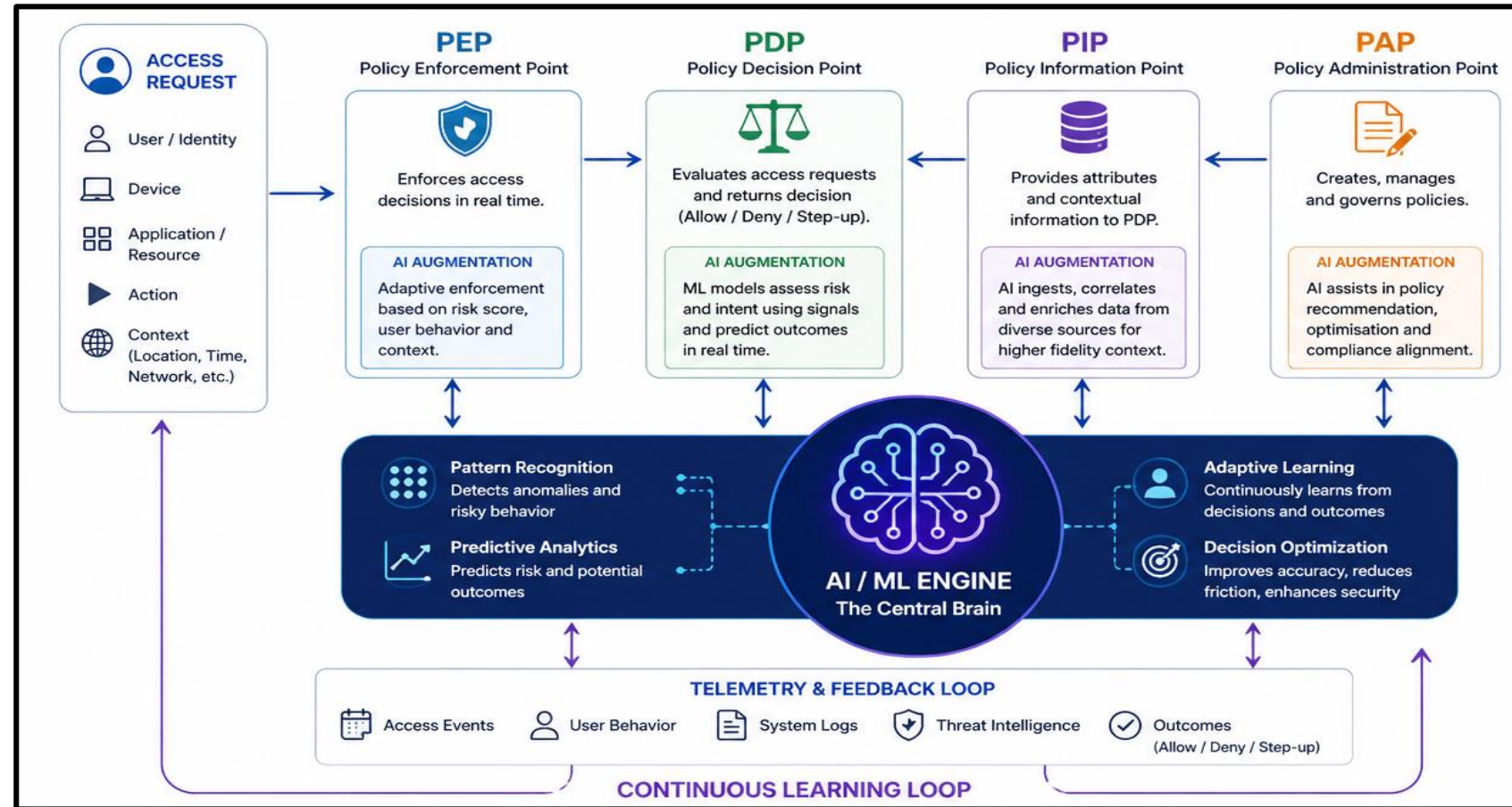
Leverage AI/ML to strengthen Identity & Access Management, **detect risks in real time, and automate governance** at scale.



AI for Dynamic Policy Engine

Let's analyse how **AI** can **augment** IAM authorisation decision-making

AI-driven IAM workflow evolves the traditional **static request-response model** into a continuous, **adaptive decisioning loop**.



Best Practices for IAM

- Know your Assets, → *Understand Business and System Architecture*
- Define your IAM Life Cycle
- Understand your Organizational Processes
- Governance is key to success
- Apply Zero Trust → *Least Privilege, and Conditional Access*
- Keep pace with new technologies → *AI*

Thankyou!

Q & A



Let's connect!

Contact: Dr. Ahmad Mohsin

a.mohsin@ecu.edu.au

Creative
thinkers
made here.